NOOB CTF

Vulnerability Assessment & Penetration Testing Report

Victim hostname	wtf.lan
Victim IP address	192.168.31.169
Assessment type	Controlled CTF / intentionally vulnerable lab
Evidence basis	User-provided screenshots and report spreadsheet

Confidentiality & scope

Only the victim host shown above is in scope. Unrelated discovered IP addresses and hostnames are omitted. Personal account details and challenge tokens are not reproduced. This report is for authorized CTF/lab learning only.

1. Executive Summary

The supplied evidence shows anonymous FTP access and file retrieval, HTTP and SSH service exposure, challenge clue decoding, and privilege escalation to root through an overly permissive sudo policy. Each finding below uses a Kioptrix-style table with a dedicated Proof of Concept row.

2. Observed Services

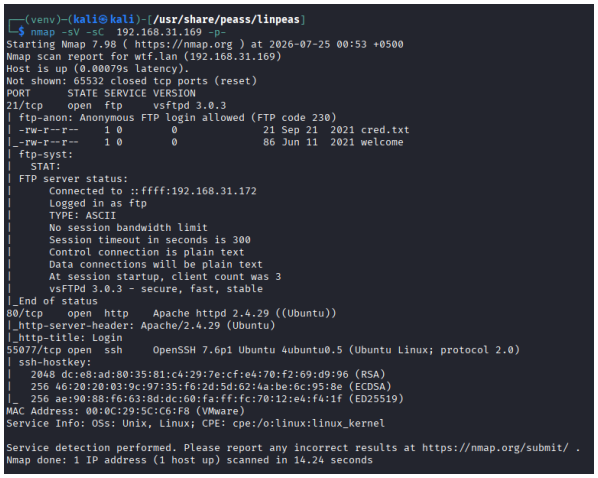
Port	Service / version	Evidence
21/TCP	FTP — vsftpd 3.0.3	Anonymous login allowed; files listed and downloaded.
80/TCP	HTTP — Apache httpd 2.4.29 (Ubuntu)	HTTP service and server banner identified by Nmap.
55077/TCP	SSH — OpenSSH 7.6p1 Ubuntu 4ubuntu0.5	SSH service identified; lab login shown in evidence.

Version note: the spreadsheet labels vsftpd 2.3.4, while the Nmap screenshot shows vsftpd 3.0.3. This report follows the screenshot and does not claim the vsftpd 2.3.4 backdoor.

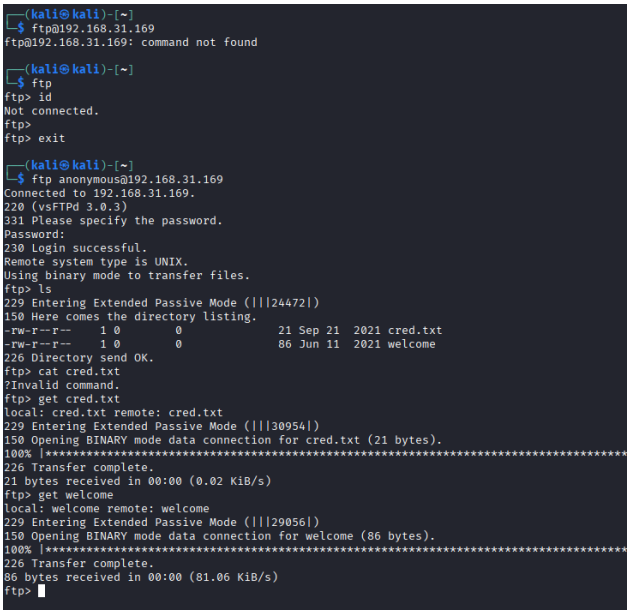
3. Findings — Kioptrix-style PoC tables

Finding 1: Anonymous FTP access and file disclosure

PORT NO	21/TCP
SERVICE NAME	FTP — vsftpd 3.0.3
SEVERITY	High
VULNERABILITY NAME	Anonymous FTP Access / File Disclosure
CVE ID	Not assigned from supplied evidence
DESCRIPTION	Nmap reports anonymous FTP login permitted. The FTP session shows anonymous login succeeded, the directory listing exposed cred.txt and welcome, and both files were downloaded.
REMEDIATION	Disable anonymous access unless required; remove sensitive files from the FTP root; restrict FTP by firewall; use SFTP where possible; review access logs.
PROOF OF CONCEPT	nmap -sV -sC -p 21 192.168.31.169 ftp 192.168.31.169 Login: anonymous (password blank if accepted) ls get cred.txt get welcome



Evidence 1. Nmap service detection for the victim.



Evidence 2. Anonymous FTP login, directory listing and file retrieval.

Finding 2: HTTP service banner disclosure

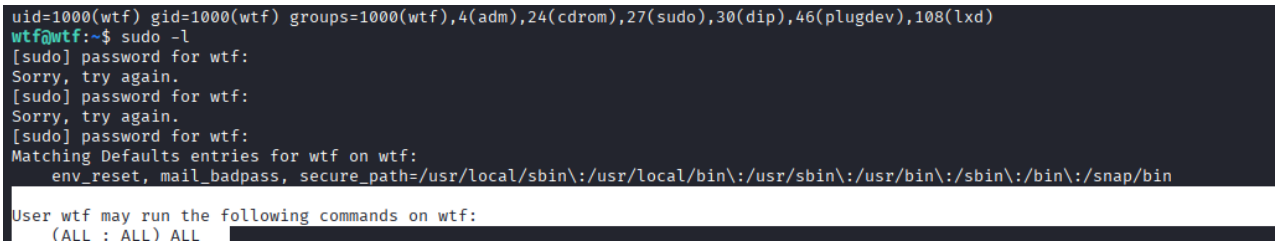
PORT NO	80/TCP
SERVICE NAME	HTTP — Apache httpd 2.4.29 (Ubuntu)
SEVERITY	Low–Medium
VULNERABILITY NAME	HTTP Service / Version Information Exposure
CVE ID	Not established
DESCRIPTION	The target exposes an HTTP service and its Apache version is identified by service detection. The supplied screenshots do not prove a specific exploitable Apache CVE; this is recorded as service/banner exposure only.
REMEDIATION	Keep Apache patched; reduce unnecessary version details in server responses; remove unused modules and pages; review application configuration and run an authenticated web assessment if authorized.
PROOF OF CONCEPT	nmap -sV -p 80 192.168.31.169 curl -I http://192.168.31.169/

Finding 3: SSH service exposure

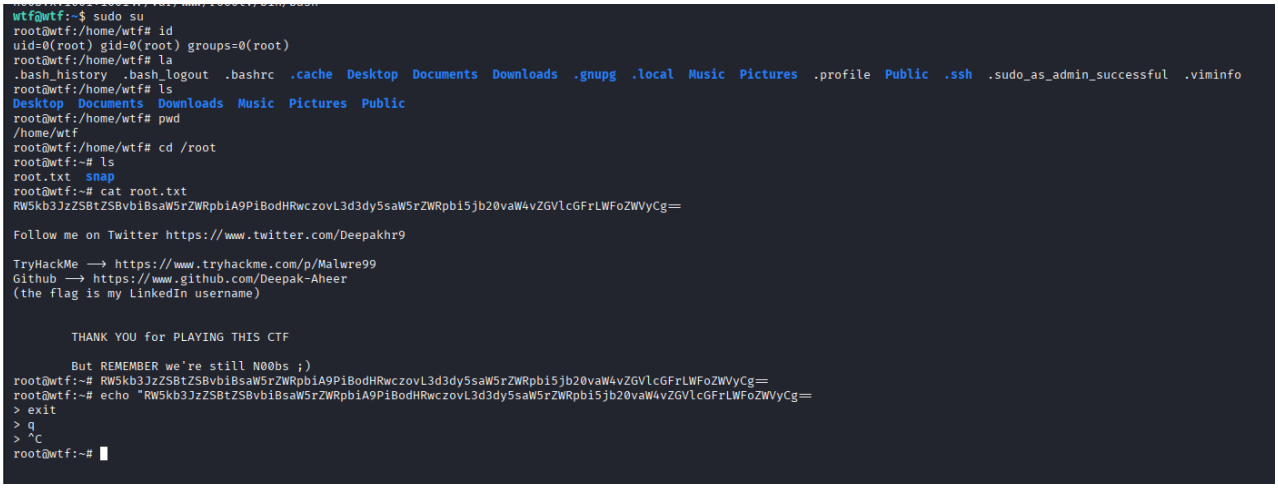
PORT NO	55077/TCP
SERVICE NAME	SSH — OpenSSH 7.6p1 Ubuntu 4ubuntu0.5
SEVERITY	Low–Medium
VULNERABILITY NAME	SSH Service Exposure / Authentication Hardening
CVE ID	Not established
DESCRIPTION	Nmap identifies SSH on TCP/55077. A screenshot shows a successful CTF user session. The evidence does not establish a specific SSH CVE or independently prove a weak-password vulnerability.
REMEDIATION	Restrict SSH to trusted management hosts; prefer key-based authentication; disable password login where feasible; update to a supported OpenSSH build; monitor authentication logs and rate-limit attempts.
PROOF OF CONCEPT	nmap -sV -p 55077 192.168.31.169 ssh -p 55077 wtf@192.168.31.169

Finding 4: Overly permissive sudo policy enables root access

PORT NO	Local privilege escalation
SERVICE NAME	sudo / sudoers configuration
SEVERITY	Critical
VULNERABILITY NAME	Excessive Sudo Permissions
CVE ID	N/A — configuration issue
DESCRIPTION	The screenshot of sudo policy indicates the user wtf can run commands with broad ALL permissions. A later screenshot shows a root shell, confirming the impact in this lab.
REMEDIATION	Remove broad ALL grants; allow only specifically required commands and arguments; audit /etc/sudoers and /etc/sudoers.d; review privileged group membership; alert on unexpected sudo/su activity.
PROOF OF CONCEPT	sudo -l # Review the listed allowed commands and privileges. # Supplied evidence shows broad ALL permissions and subsequent root access.



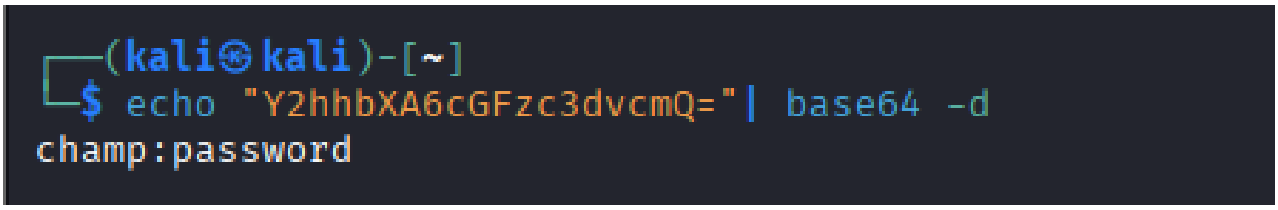
Evidence 3. Sudo policy output.



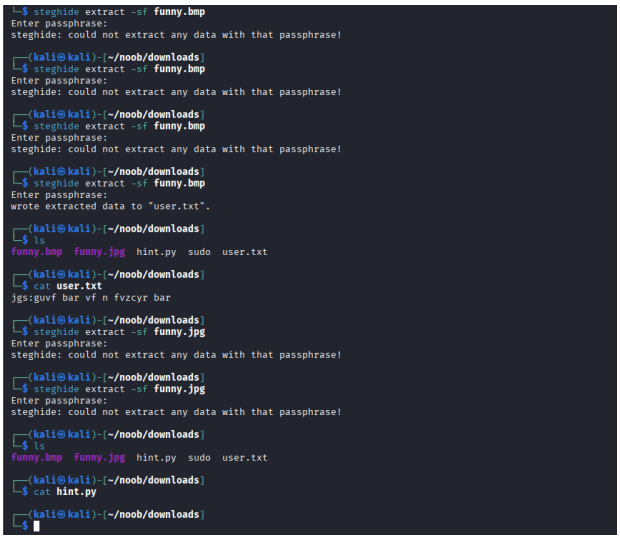
Evidence 4. Root shell evidence; challenge token omitted.

Finding 5: CTF clue material exposed through retrieved files

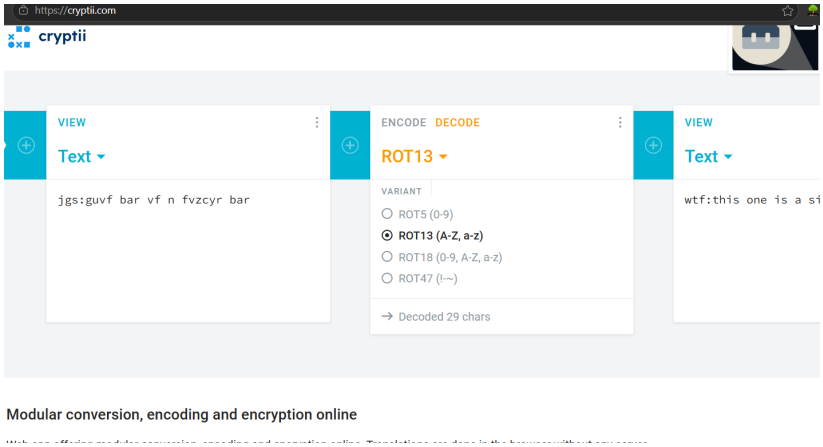
PORT NO	Supporting evidence for FTP finding
SERVICE NAME	Downloaded files / local challenge artifacts
SEVERITY	Informational
VULNERABILITY NAME	Recoverable Encoded and Steganographic Clues
CVE ID	N/A — CTF challenge technique
DESCRIPTION	Supplied screenshots show Base64 decoding, steganographic extraction from funny.bmp to user.txt, and ROT13 decoding. These are challenge steps rather than independent software vulnerabilities; exposure is tied to publicly retrievable files.
REMEDIATION	Do not store secrets or sensitive clues in publicly readable directories; remove challenge artifacts from exposed services; review files for credentials and sensitive data.
PROOF OF CONCEPT	echo 'Y2hhbXA6cGFzc3dvcmQ=' | base64 -d steghide extract -sf funny.bmp cat user.txt tr 'A-Za-z' 'N-ZA-Mn-za-m' < user.txt



Evidence 5. Base64 decoding clue.



Evidence 6. Steganography extraction.



Evidence 7. ROT13 clue decoding.

4. Risk Summary

Finding	Severity	Priority / action
Excessive sudo permissions	Critical	P1 — remove broad ALL permissions.
Anonymous FTP file disclosure	High	P1 — disable anonymous access and remove exposed files.
SSH exposure	Low–Medium	P2 — restrict access and harden authentication.
HTTP banner exposure	Low–Medium	P3 — patch and reduce unnecessary disclosure.
CTF clue recovery	Informational	Remove sensitive artifacts from public locations.

5. Limitations and Conclusion

The report is based on the supplied screenshots and spreadsheet. The evidence confirms ports 21, 80 and 55077 as shown in the Nmap output. No specific CVE is assigned where the screenshots do not substantiate one. Prioritize fixing sudo permissions and anonymous FTP exposure, then harden SSH and HTTP and retest.